

Procedură de Gestionare a Parolelor

🚦 Organizație imaginară: ELECTRONIX ENERGY S.A.

🚦 Scopul procedurii

Această procedură are ca scop stabilirea unor reguli clare și coerente privind crearea, stocarea, utilizarea și actualizarea parolelor în cadrul organizației ENERGOSSEC S.A. Scopul este de a proteja sistemele informatice, datele sensibile și infrastructura critică împotriva accesului neautorizat și a potențialelor amenințări cibernetice. Procedura respectă cerințele standardelor internaționale ISO/IEC 27001 și NIST SP 800-53, promovând o cultură organizațională orientată spre securitatea informațiilor.

🚦 Domeniul de aplicare

Această procedură se aplică tuturor angajaților, colaboratorilor, contractorilor și partenerilor care utilizează resurse informatice puse la dispoziție de ENERGOSSEC S.A. Procedura acoperă accesul la:

- Stații de lucru cu sisteme de operare Windows și Linux
- Servere interne, aplicații software de tip cloud și aplicații on-premise
- Baze de date operaționale și sisteme SCADA (Supervisory Control and Data Acquisition)
- Conturi de e-mail corporative și aplicații specifice sectorului energetic

1. Cerințe generale conform ISO/IEC 27001 și NIST

Standardele ISO/IEC 27001 și NIST recomandă implementarea unor măsuri stricte pentru controlul accesului, printre care:

- Accesul trebuie acordat în funcție de principiul „nevoii de a cunoaște” și al minimului privilegiu
- Sistemele trebuie să utilizeze autentificare multifactor (MFA), acolo unde este posibil
- Parolele trebuie să fie unice pentru fiecare cont și să fie stocate criptat (ex: algoritmi bcrypt, PBKDF2)
- Politicile de securitate trebuie aplicate automat, prin configurarea controalelor tehnice, precum GPO pentru Windows sau PAM pentru Linux

2. Crearea parolelor

Parolele trebuie să fie create în așa fel încât să nu poată fi ghicite sau sparte cu ușurință. Fiecare parolă:

- Trebuie să aibă o lungime minimă de 12 caractere
- Trebuie să conțină cel puțin o literă mare (A-Z), o literă mică (a-z), o cifră (0-9) și un caracter special (!@#\$%^&*)

- Nu trebuie să conțină numele utilizatorului, numele companiei, date de naștere sau cuvinte comune din dicționar
- Poate fi generată automat cu un manager de parole sau creată manual, respectând regulile de mai sus

3. Stocarea parolelor

Parolele nu trebuie stocate în format text clar (plaintext). Sunt permise doar metode securizate de stocare:

- Stocarea criptată cu algoritmi standard (bcrypt, SHA-512 cu salt, PBKDF2)
- Utilizarea unui seif digital aprobat de companie (ex: Bitwarden, KeePass)
- Parolele administratorilor de sistem vor fi păstrate într-un sistem de tip „password vault” cu acces controlat
- Este interzisă stocarea parolelor în fișiere text, e-mailuri sau agende fizice

4. Utilizarea parolelor

Fiecare utilizator are responsabilitatea de a menține parola proprie confidențială. Reguli de utilizare:

- Nu se permite partajarea parolei cu alți utilizatori, indiferent de poziția în organizație
- Este interzisă introducerea parolei pe site-uri nesecurizate sau în aplicații terțe neautorizate
- Parolele nu trebuie salvate în browser, decât dacă se folosește un manager de parole autorizat

5. Schimbarea și actualizarea parolelor

Pentru a minimiza riscul de compromitere, parolele trebuie actualizate periodic:

- Fiecare parolă trebuie schimbată cel puțin o dată la 90 de zile
- Parolele trebuie schimbate imediat în cazul suspiciunii de compromitere a contului
- Este interzisă reutilizarea ultimelor 5 parole utilizate pentru același cont
- Utilizatorii vor fiificați automat cu 7 zile înainte de expirarea parolei

6. Criterii de complexitate

Pentru a garanta un nivel minim de securitate, toate parolele trebuie să respecte următoarele criterii:

- Să conțină cel puțin o literă mare (ex: „T”)
- Să conțină cel puțin o literă mică (ex: „r”)
- Să conțină cel puțin o cifră (ex: „7”)

- Să conțină cel puțin un simbol special (ex: „!”)
- Să nu conțină informații personale ușor de identificat sau ghicit (ex: prenume, CNP, adresa de email)

7. Monitorizarea respectării procedurii

Departamentul IT este responsabil de monitorizarea conformității cu această procedură. Măsurile includ:

- Audituri de securitate trimestriale asupra conturilor și setărilor de autentificare
- Implementarea de politici GPO în Active Directory pentru conturile Windows
- Utilizarea de module PAM și fișiere de configurare în UNIX pentru impunerea regulilor
- Alertarea automată a departamentului IT la detectarea unui comportament anormal legat de parole
- Documentarea abaterilor și aplicarea de măsuri corective în termen de 24 de ore

8. Instrucțiuni pentru angajați

Toți angajații trebuie să respecte următoarele instrucțiuni practice:

- La prima autentificare, utilizatorii trebuie să schimbe parola temporară primită
- Este obligatorie activarea autentificării cu doi factori (2FA), folosind SMS sau aplicații dedicate (ex: Google Authenticator)
- În cazul pierderii sau uitării parolei, utilizatorul trebuie să contacteze de urgență echipa de suport IT
- Parolele trebuie actualizate imediat ce se primește o solicitare oficială în acest sens
- Angajații sunt responsabili de securitatea conturilor lor și trebuie să raporteze orice activitate suspectă

Exemple:

- Parolă validă: *G7r!cLz@2kWq* (complexă, lungă, aleatorie)
- Parolă incorectă: *parola123* (simplă, ușor de spart, previzibilă)